A&L Goodbody

Data Protection and GDPR - Overview

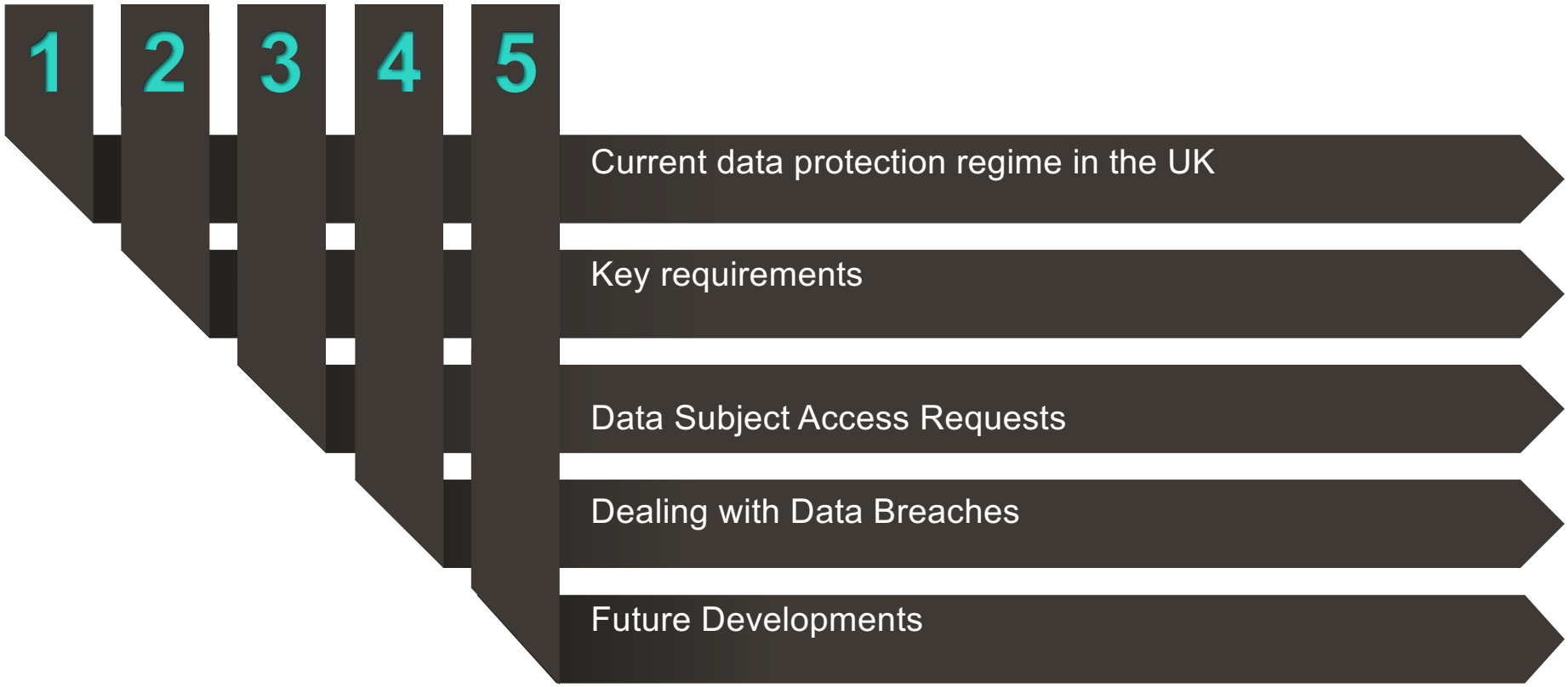
Aisling Byrne

Ulster University

1 December 2023

A&L Goodbody

Introduction



A&L Goodbody

Current data protection regime

Legislative Landscape

UK GDPR regime - two main pieces of legislation:

- EU GDPR incorporated into UK law (Retained Regulation (EU) 2016/679) - **UK GDPR**
- Parts of the **Data Protection Act (DPA) 2018** relating to general personal data processing, powers of the IC, sanctions and enforcement

Both UK GDPR + DPA 2018 should be read together

Data Protection - Key terms

Personal Data

E.g. contact details, age, DOB, online identifier

Data relating to identified or identifiable individuals (***data subject***)

Special Category Data

E.g. data relating to health, genetics, biometrics, sex, race, religion, trade union membership, political opinion

Additional processing condition under Article 9 must be satisfied

Processing

E.g. collecting, organising, adapting, obtaining, recording, keeping, transferring or disclosing

Very widely defined

Data Controller

Determines the **purpose(s)** and the **means** of processing.

I.e. 'why' and 'how' data is processed.

Data Processor

Processes personal data on behalf of a data controller

Data Protection Principles

- Lawfulness, fairness & transparency
- Purpose Limitation
- Data minimisation
- Accuracy
- Storage Limitation
- Integrity & confidentiality
- Accountability

Lawfulness - The Legal Basis of Processing

Consent 1

not always the best mechanism to legitimise processing - controllers should consider whether another ground is more appropriate

Performance of a contract 2

where processing is necessary for the performance of a contract or to take steps to enter into a contract

Compliance with a legal obligation 3

legal obligation must be laid down by UK law

Protect vital interests 4

Where processing is necessary to protect someone's life

Public interest 5

carrying out a specific task in the public interest which is laid down by law, or exercising official authority

Legitimate interests 6

processing is necessary for the purposes of legitimate interests of the controller or a third party, except where such interests are overridden by the interests, rights or freedoms of the data subject

How can businesses lawfully process personal data?

Processing personal data

Article 6, UK GDPR

1. Consent
2. Legal Obligation
3. Performance of a contract
4. Legitimate Interests

Processing special category data

Article 9, UK GDPR

1. Explicit consent
2. Necessary for carrying out employment obligations
3. Necessary for substantial public interest reasons

Key obligations

Data processing: roadmap to compliance

Identify **personal data** including any **special category data**

Decide on what **lawful basis**/ **additional processing condition** you will rely on.

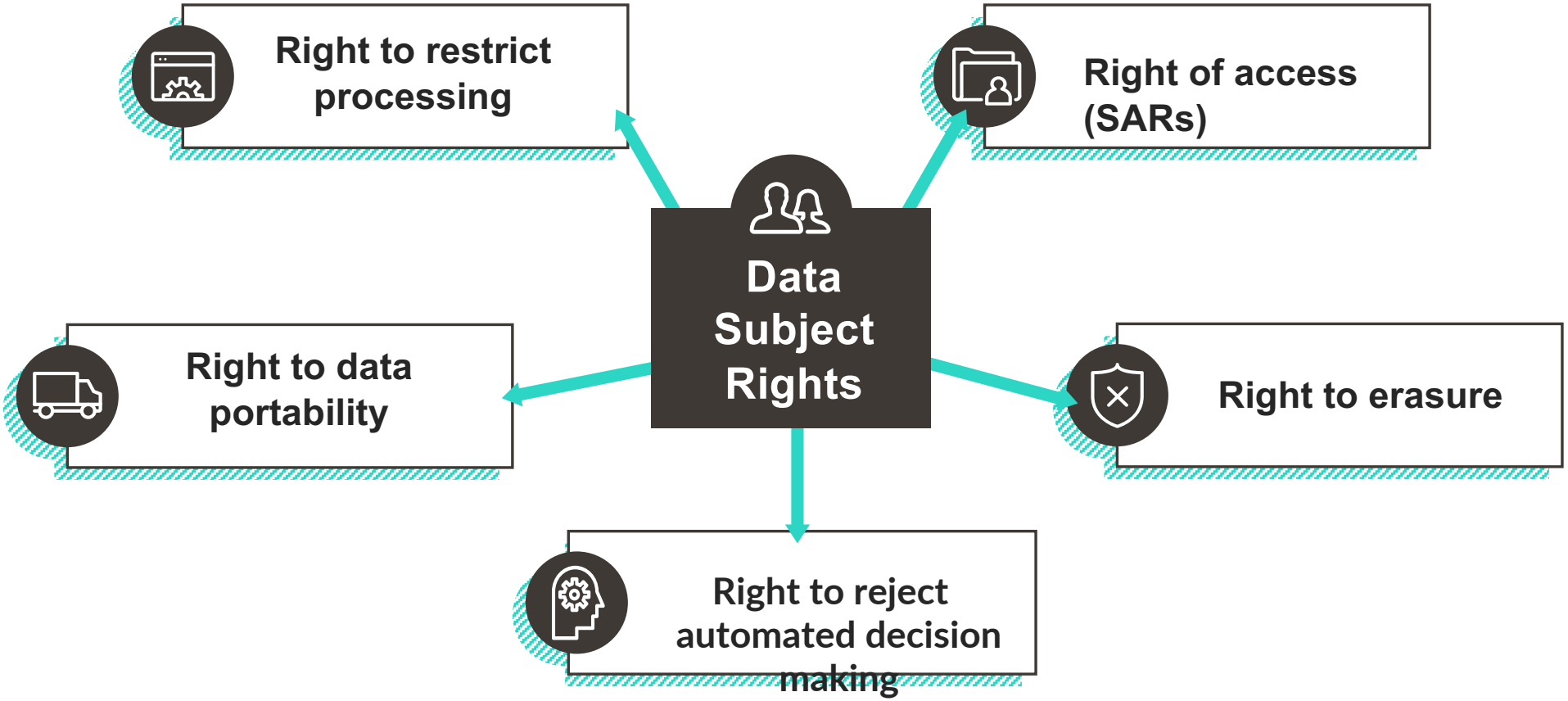
Consider if a **data privacy impact assessment** is needed

Transparency: provide data subjects with information as to how their data will be used.

Process personal data (NB: processing is widely defined)

Record keeping: Keep a record of processing activities (Art 30, UK GDPR)

What rights do data subjects have?



A&L Goodbody

Right of Access under the DPA 2018 and UK GDPR

How have Data Subject Access Rights changed?

Data Protection Act 1998

- Section 7 DPA 1998 - data subject access rights
- Subject access request had to be made in **writing**
- **Fee** of £10 was payable
- Controller could ask for evidence of identity
- Comply “promptly” – at the latest within 40 days after receipt of the request

GDPR- Subject Access Rights - Article 15

The data subject shall have the right to obtain from the controller confirmation as to whether or not personal data concerning him or her are being processed, and, where that is the case, access to the personal data and the following information: (it may be set out in a privacy notice):

- The purposes of the processing
- The categories of personal data
- The recipients or categories of recipient to whom personal data is disclosed
- The retention period for storing the personal data or, where this is not possible, the criteria for determining how long you will store it
- The existence of the data subject's right to request rectification, erasure or restriction or to object to such processing
- The right to lodge a complaint with the ICO or another supervisory authority
- Information about the source of the data, where it was not obtained directly from the individual
- The existence of automated decision-making (including profiling)
- The safeguards provided where personal data is transferred to a third country or international organisation.

Hidden Costs - 2020 Survey by Privacy Specialist Guardum

UK businesses are spending **24 person-years** annually processing DSARs

DSARs cost £4,884.53 per request on average

DSARs take 66 working hours to process on average

How can a DSAR be made?

Raising a DSAR?

- DSARs – verbally, in writing, by video, using social media
- You can ask for information to verify identity
- Clock can be stopped until requested information received
- ID documents should be requested promptly
- Third party request - be satisfied that the third party making the request has authority

Timescale for response?

Deadline

- Compliance - without undue delay and within **1 month** of receipt of the request
- From the date of receipt to the corresponding date the following month
- Time can be extended if:
  - the request is complex
  - a number of requests have been received from the data subjects
- If extending time you must notify the data subject within one month and explain why

A&L Goodbody

Third Party Information

Information about other individuals?

- You do not have to comply with a DSAR if doing so means disclosing information which identifies another individual except where:
  - The other individual has consented to the disclosure; or
  - It is reasonable to comply with the request without that individual's consent, considering:
    - the type of information that you would disclose;
    - any duty of confidentiality owed to the third party;
    - any steps taken by you to try to get the third party's consent;
    - whether the third-party individual is capable of giving consent; and
    - any stated refusal of consent by the third-party individual.

Exemptions

GDPR exemptions - manifestly unfounded or excessive?

1 Manifestly unfounded

- Individual has no intention of exercising right of access.
- Malicious motive to harass the organisation.
- Intention is to cause disruption.
- Unsubstantiated accusations made with malice.
- Different DSARs sent regularly to cause disruption.

2 Excessive

Request is **clearly and obviously** unreasonable taking into account the **burden of costs involved** and all the **circumstances** of the request:

- Nature of requested information;
- Context: relationship between requestor and organisation;
- If refusal would cause individual substantial damage;
- Available resources;
- If request repeats previous requests;
- Overlaps with other requests.

Options?

- **Refuse** to respond to DSAR
- Charge a reasonable **fee**
- **Extend response time** for a further two months

DPA 2018 Exemptions

DPA outlines additional exemptions which apply where data:

- Is subject to legal or litigation privilege.
- Is purely personal or for household activity.
- Is a reference given (or to be given) in confidence for employment, training or educational purposes.
- Is processed for the purposes of management forecasting or management planning in relation to a business or other activity to the extent that complying with a subject access request would prejudice the conduct of the business or activity.
- Consists of records of intentions in relation to negotiations between the employer and employee to the extent that compliance with the subject access request would be likely to prejudice the negotiations.
- Contains the personal data of a third party.
- Is of the type which would be likely to prejudice the prevention or detection of crime, or the apprehension or prosecution of offenders if disclosed.

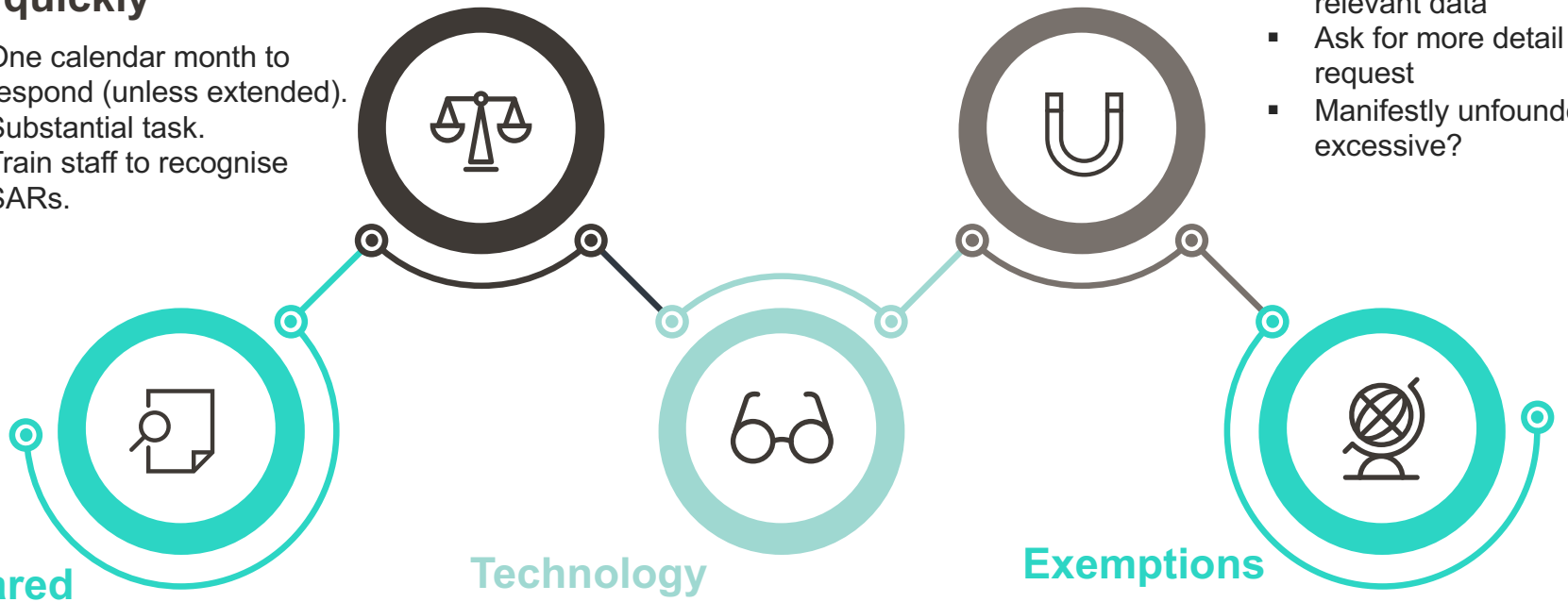
Top Tips

Act quickly

- One calendar month to respond (unless extended).
- Substantial task.
- Train staff to recognise SARs.

Scope

- Review the scope
- Consider how to search for relevant data
- Ask for more detail to refine request
- Manifestly unfounded / excessive?



Be Prepared

- Have clear, robust policies in place to cover SARs and data retention
- Identify key stakeholders (IT, HR, Legal)

Technology

- Consider how technology can assist your response to a SAR.

Exemptions

- Not everything is relevant!
- Legal privilege?
- Manifestly excessive or unfounded?
- Data created after DSAR?

Headlines

- MOJ –**2022** - Enforcement Action by the ICO
- Breach of **Section 45 of the DPA 2018 and Article 15 of the UK GDPR**
- Failure to provide DSAR information to 7,753 data subjects unacceptable (25 had received no response and 7,728 had received only a partial response)

Data Breaches

Dealing with a data breach

Personal data breach

"*Accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data…*"

Mandatory notification to ICO

Unless breach is "*unlikely to result in a risk*" to the rights and freedoms of data subjects.

Timeframe

"*Without undue delay*" and in any event, within 72 hours.

Records

Document data breaches, specifically the:

- Facts;
- Effect(s) of breach; and
- Remedial action(s) taken.

Obliged to notify individuals

If a data breach is "*likely to result in a high risk*" to the rights and freedoms of individuals.

A&L Goodbody

Should we report a breach?

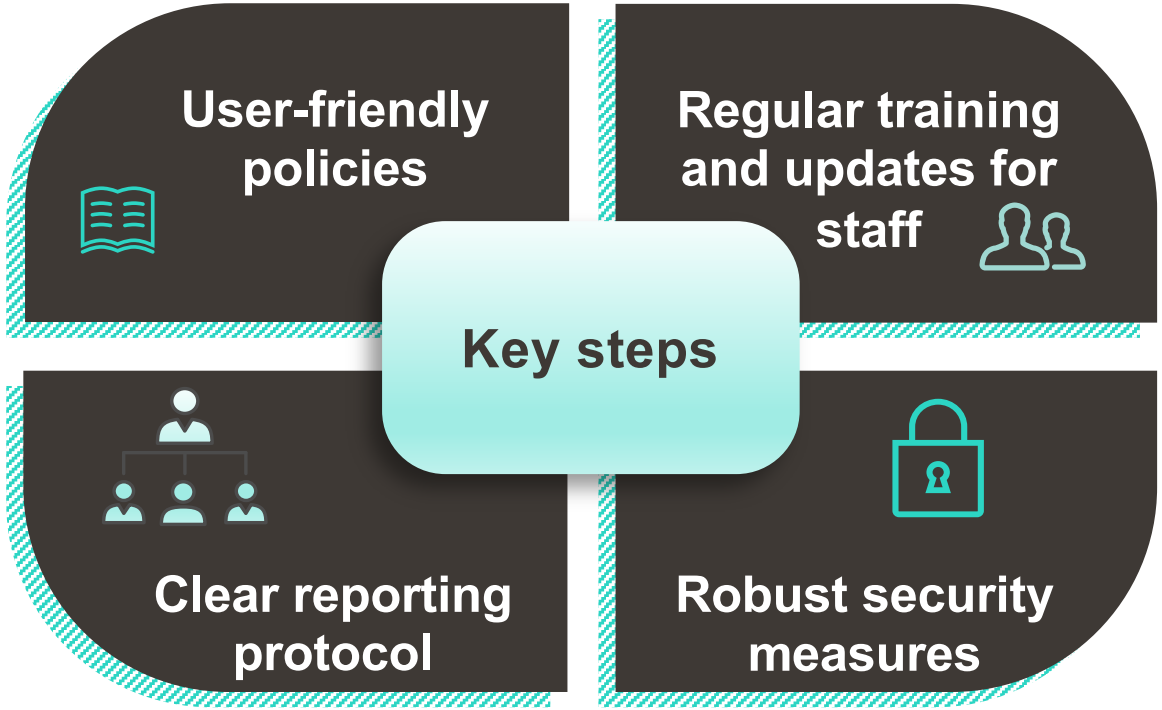
Consideration should be given to the following factors:

1. The type of breach;
2. The nature, sensitivity, and volume of personal data;
3. Ease of identification of individuals ;
4. Severity of consequences for individuals;
5. Special characteristics of individuals;
6. Special characteristics of the data controller; and
7. The number of affected individuals.

"If in doubt, the data controller should err on the side of caution and notify".

- EU Guidelines

Data Breaches: Mitigating the risk



A&L Goodbody

ICO Fines 2020/2021

1. ICO fines increased by 1580% in 2020/2021
2. £42million in fines during financial year 2020/2021

ICO fines

- **Mermaids** – UK charity offers support to gender diverse children, young people and their families
- CEO set up an internet email group in 2016 to exchange emails with 12 Trustees
- Default security settings for the group – publicly viewable messages
- 2019 – mother contacted by Sunday Times journalist who, via a search engine, found confidential emails including telephone number, information relating to her child's mental and physical health.
- 550 data subjects, 4 of whom were children, information was special category data in the case of 15 data subjects
- ICO issued a fine in July 2021 - **£25,000** - 2.8% of the charity's annual turnover.

ICO fines

- **HIV Scotland –** email to 105 people, blind copy function was not used, 65 of the addresses identified people by name
- Human error
- An assumption could be made about the email recipients HIV status or risk
- ICO found - Staff training was inadequate, no employee data protection policy outlining what was expected of staff
- ICO issued a fine of **£10,000** in October 2021

Future developments

Data – A New Direction?

July 2022 – Data Protection and Digital Information Bill introduced

"We will be replacing GDPR with our own business and consumer friendly British data protection system"

DPDI Bill – will amend UK GDPR and the Data Protection Act 2018

300 pages long – passage of Bill expected Spring 2024

Questions?

A&L Goodbody

Thank you

A&L Goodbody